elsewhere. By removing the VPN requirement and establishing those constraints as core, shared operational policies, ACME ensured consistent access decisions regardless of where the request originated. Users with the correct identity, device posture, and context could access the tools from anywhere, while unauthorized access was blocked even from inside the network.

Over time, the security team noticed a steady decrease in VPN-only access paths, IP-based allowlists, and special-case firewall rules. This trend showed that trust was no longer based on network location but on evaluated context. Reducing reliance on the perimeter didn't mean removing network controls entirely; it meant moving them from primary gatekeepers to supporting signals. This change clearly indicated that ACME's zero-trust architecture was becoming both stronger and more adaptable across services.

15.5.5 Decline in authorization exceptions

Authorization exceptions often indicate that the access-control model cannot fully represent the organization's actual needs. Before PBAC, ACME frequently managed edge cases with one-off rules: hard-coded role checks in application code, special VPN groups, IP allowlists, or temporary flags that bypassed standard authorization logic. These exceptions solved immediate problems but accumulated over time, making access behavior more difficult to understand, test, and audit.

Sam's team started measuring how often these exceptions occurred as ACME implemented a zero-trust architecture. They monitored several indicators: the number of code changes that added custom authorization logic, the use of emergency bypass flags, the amount of access granted through special-case configurations, and how often manual approvals were needed to override normal controls. Early metrics revealed that many exceptions existed simply because no shared policy could fully express the intended rule.

As foundational and shared operational policies expanded, these exceptions became less necessary. For example, engineering teams previously used manual overrides to allow after-hours deployments during incidents. Once the on-call deployment rule was expressed as a shared operational policy,